

How Well Do Large Language Models Serve as End-to-End Secure Code Agents for Python?

Jianian Gong
jianian_gong@buaa.edu.cn
School of Computer Science and
Engineering, Beihang University
Beijing, China

Nachuan Duan
nc_duan@buaa.edu.cn
School of Computer Science and
Engineering, Beihang University
Beijing, China

Ziheng Tao
tzh588577@163.com
School of Computer Science and
Engineering, Beihang University
Beijing, China

Zhaohui Gong
gzh1198073707@163.com
School of Computer Science and
Engineering, Beihang University
Beijing, China

Yuan Yuan*
yuan21@buaa.edu.cn
School of Computer Science and
Engineering, Beihang University
State Key Laboratory of Software
Development Environment
Zhongguancun Laboratory
Beijing, 100191, China

Minlie Huang
aihuang@tsinghua.edu.cn
Tsinghua University
Zhongguancun Laboratory
Beijing, China

Abstract

The rapid advancement of large language models (LLMs) such as GPT-4 has revolutionized the landscape of software engineering, positioning these models at the core of modern development practices. To fully realize their potential in producing secure source code autonomously, LLMs must not only generate code but also identify and repair vulnerabilities in their outputs, thereby improving security iteratively. Despite growing prominence, LLMs' effectiveness in performing such **end-to-end tasks** remains unexplored. This paper bridges this gap by systematically investigating the capability of LLMs to generate source code, evaluate **their own outputs** for vulnerabilities, and apply necessary repairs to improve the security of **their self-generated code**.

Specifically, we studied the ability of GPT-3.5 and GPT-4 to identify and repair vulnerabilities in the code generated by four popular LLMs including themselves (GPT-3.5, GPT-4, Code Llama, and CodeGeeX2). By manually or automatically reviewing 4,900 pieces of code, our study reveals that: (1) LLMs generate over 75% vulnerable Python code in given scenarios; (2) LLMs such as GPT-3.5 and GPT-4 are unable to precisely identify vulnerabilities in the code they generated; (3) GPT-3.5 and GPT-4 can achieve 33.2%~59.6% success rates in repairing the insecure code produced by the 4 LLMs, but they both perform poorly when repairing self-produced code, indicating self-repair "blind spots". To address the limitation of a single round of repair, we developed a lightweight tool using LLMs as agents to construct safer source code through an iterative repair

procedure based on the insights gained from our study. Experiments show that, assisted by semantic analysis engines, our tool significantly improves the success rates of repair to 65.9%~85.5%.

CCS Concepts

• **Software and its engineering** → **Software development techniques; Software verification and validation**; • **Security and privacy** → *Software and application security*.

Keywords

Software security, large language models, end-to-end, code generation, vulnerability detection and repair, CWE

ACM Reference Format:

Jianian Gong, Nachuan Duan, Ziheng Tao, Zhaohui Gong, Yuan Yuan, and Minlie Huang. 2025. How Well Do Large Language Models Serve as End-to-End Secure Code Agents for Python?. In *Proceedings of The 29th International Conference on Evaluation and Assessment in Software Engineering (EASE 2025)*. ACM, New York, NY, USA, 10 pages. <https://doi.org/XXXXXXX.XXXXXXX>

1 INTRODUCTION

Transformer-based large language models have fundamentally reshaped software engineering in recent years. As LLM-powered programming assistants such as GitHub Copilot widely adopted by IT companies and individual developers, traditional developer-centered software engineering (i.e., Software 1.0 and Software 2.0 where all source code is manually written) is rapidly evolving to LLM-centered software engineering (i.e., Software 3.0 where most source code is generated by AI). According to research by GitHub, its Copilot contributes to more than 46% of all source code that its 1.3 million users have developed [14].

As more LLM-generated code is accepted by developers and thus becomes part of the software, its security is gaining increasing concern. Previous studies [13, 17, 18, 20, 21, 25, 29] have revealed that although large language models are capable of generating functionally correct code, they are not free of security vulnerabilities.

*Corresponding author.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

EASE 2025, 17–20 June, 2025, Istanbul, Türkiye

© 2025 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM ISBN 978-x-xxxx-xxxx-x/YY/MM

<https://doi.org/XXXXXXX.XXXXXXX>

Table 1: Comparison with representative related work evaluating the security of LLM-generated code

Related Work ¹	Studied Language(s)	Automated Review	Manual Review	#Studied CWEs	#Studied LLM(s)
Pearce et al.[25]	Python, C, Verilog	CodeQL	✓	25	1
Khoury et al.[18]	C, C++, Python, HTML, Java	✗	✓	14	1
Asare et al.[13]	C, C++	✗	✓	6	1
Sandova et al.[29]	C	✗	✓	6	1
Fu et al.[17]	Python, JavaScript	CodeQL, Bandit, ESLint	✗	16	3
Liu et al.[20]	C, C++, Java	CodeQL	✗	17	1
Our work	Python	CodeQL, Bandit	✓	69	4

¹ Only studies which are based on code generated by LLMs and classify vulnerabilities according to CWEs are included in this comparison

Therefore, raw LLM-generated source code cannot be trusted to be deployed in security-sensitive scenarios.

The increasingly significant role of LLMs in software engineering, coupled with disturbing vulnerabilities in the code they generate, compels us to explore methods for producing safer code with LLMs. Standard end-to-end software development practices, which include writing, reviewing, and refactoring code, result in significantly higher quality compared to focusing solely on code writing [15]. This inspires us to consider: *How well do large language models function as comprehensive, end-to-end secure code agents?* In the context of this research, *end-to-end* refers to a process wherein a code snippet is not only generated but also undergoes review and, if necessary, remediation of identified vulnerabilities before being presented to users. To achieve this level of competence, LLMs must demonstrate proficiency in three key areas: generating functionally correct code, conducting thorough self-reviews of their output, and effectively repairing any detected security flaws.

Our investigation focuses specifically on evaluating these capabilities within the Python programming ecosystem. This choice is motivated by two primary factors: (1) Python’s widespread adoption in web development, a domain where security considerations are paramount; and (2) the scarcity of existing research focusing on the security implications of AI-generated Python code.

Hence, we seek answers to the following research questions:

RQ1: How do LLMs perform when generating Python code in security-sensitive scenarios? This research question aims to address the lack of exclusive research on the security of LLM-generated Python code. Additionally, the identified insecure code in this RQ will be used in subsequent research questions.

RQ2: How effective are LLMs in identifying LLM-generated code vulnerabilities? This research question seeks to investigate LLMs’ potential to self-review their generated code, as accurate identification of vulnerabilities is crucial for mitigating weaknesses in the source code.

RQ3: How effective are LLMs in repairing LLM-generated code vulnerabilities? This RQ investigates LLMs’ capability to self-repair their generated code, which is the final and most crucial step in constructing secure source code.

RQ4: How effective is an iterative strategy in improving LLMs’ repair capability? A single round of vulnerability detection and repair may not be sufficient to eliminate weaknesses in code. To address this, we introduce an iterative strategy that allows LLMs to repair the generated code through multiple attempts with feedback

information provided. **This research question synthesizes RQ1 through RQ3, serving as the focal point of our study.**

Previous studies such as [25, 26, 38] have examined, respectively, the ability of LLMs in generating secure code, detecting vulnerabilities in real-world code, or repairing them, similar to our effort in RQ1, RQ2, or RQ3. However, they suffer from limitations such as a narrow range of CWEs and restricted code review methods. In terms of RQ1, a comparison with representative work is detailed in Table 1. **Furthermore, there has been no comprehensive pipeline study integrating the processes of generation, detection, and repair to evaluate the potential of LLMs to produce secure code in an end-to-end manner, a gap that our RQ4 aims to address.**

Our novel contributions are as follows:

(1) We present a systematic study evaluating the performance of 4 LLMs in generating secure Python code across 67 CWEs, offering a more extensive analysis than previous research as well as addressing the lack of relevant research focusing on Python. Overall, we found that the 4 tested LLMs generated over 75% vulnerable code on the SecurityEval benchmark. Meanwhile, we made several novel discoveries such as self-repair “blind spots” of LLMs.

(2) To the best of our knowledge, we are the first to conduct a study on LLMs’ efficacy in judging and fixing **insecure code generated by LLMs themselves**, while previous work focuses primarily on manually written code in open-source projects. Our experiments revealed that GPT-3.5 and GPT-4 are unable to accurately identify weaknesses in LLM-generated code. While they achieve certain success rates in repairing the insecure code produced by the 4 LLMs (33.2% and 59.6% respectively), they perform poorer fixing self-produced code.

(3) We designed a tool using LLMs as agents to produce much safer code through a simple feedback-driven iterative self-repair process. The tool achieves 65.9%~85.5% success rates of repair when using GPT-3.5 or GPT-4 as the code generator and repairer.

For the purpose of open science, we released the artifacts of this paper in our repository¹.

2 STUDY SETTING

2.1 Studied Dataset

SecurityEval is a dataset dedicated to measuring the security of machine learning-based code generation techniques[30]. In its current

¹<https://github.com/jianian0318/LLMSecureCode>

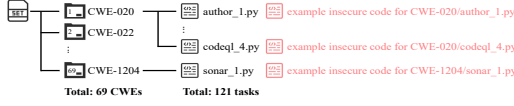


Figure 1: The structure of SecurityEval

version, the dataset contains 121 code completion tasks in Python, all of which are exposed to the potential risk of a certain CWE. Overall, these tasks cover 69 CWEs. The dataset also contains an example vulnerable solution for each generation task. Fig. 1 depicts the structure of SecurityEval.

We chose SecurityEval because (1) it was specially designed for evaluating the security of LLM-generated code, which is highly relevant to this work; (2) it covers the widest (by the time we conclude this research) range of 69 CWEs (121 scenarios), making our work more comprehensive than previous relevant ones [18, 21, 25]; (3) all of its code generation tasks are presented in Python, which matches our research goal.

2.2 Studied Large Language Models

(1) **GPT-3.5** is a well-known large language model with 175B parameters proposed by OpenAI in 2022. It is capable of understanding and generating natural language text or code. We use gpt-3.5-turbo-0125 in the study. We choose GPT-3.5 because it is one of OpenAI’s most popular models which powered ChatGPT to gain more than 100 million active users in 2023 [22].

(2) **GPT-4** is a multi-modal large language model introduced by OpenAI in 2023, capable of producing more accurate and secure responses [24]. The specific model used in the study is gpt-4-0613. GPT-4 is included in this work because it is one of OpenAI’s most advanced models, showing remarkable performance on code generation benchmarks such as HumanEval [6].

(3) **Code Llama** is a code language model introduced by Meta in 2023. It was specially trained for code-relevant tasks based on the LLaMA 2 model, with excellent performance in code generation [28]. The specific model used in the study is Code Llama-70B. We include Code Llama in our research because it is an outstanding representation of open-source code language models.

(4) **CodeGeeX2** is an open-source code language model with 6B parameters, developed jointly by Tsinghua University and Zhipu AI. It is based on the ChatGLM2 architecture and tailored for code-relevant tasks such as code generation, completion, interpretation, and cross-programming language translation [4][5]. CodeGeeX2 was selected for our study because of its strong performance among lightweight LLMs for code [37].

Our research exclusively considers GPT-based large language models due to their state-of-the-art performance and their widespread use as programming assistants such as GitHub Copilot.

2.3 Methodology

2.3.1 Methodology for RQ1~RQ3. Fig. 2 shows the overall workflow of RQ1~RQ3, which goes in a pipeline fashion. The overall procedure aims to assess LLMs’ end-to-end capability to generate secure code.

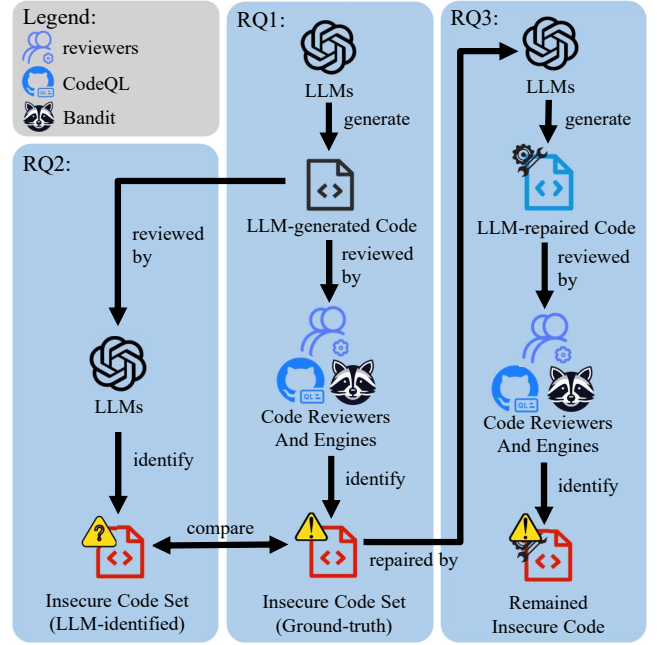


Figure 2: Workflow of RQ1~RQ3

In RQ1, we prompt GPT-3.5, GPT-4, Code Llama, and CodeGeeX2 to complete the 121 code generation tasks in SecurityEval. Results with syntax errors will be re-generated until free of errors. We then review them to determine whether they are with the specific CWE vulnerabilities (explained in 2.3.3) and draw conclusions.

In RQ2, we prompt large language models to inspect every piece of code generated in RQ1 for the presence of the corresponding CWE vulnerability. We then use the review results from RQ1 as the ground truth to evaluate the LLMs’ ability to identify weaknesses in their self-produced code.

In RQ3, the vulnerable code identified in RQ1 will be provided to LLMs for repair, along with information about its corresponding CWE. The Repaired code produced by these models will then undergo the review procedure again. We will assess the LLMs’ capability of repairing self-produced code based on these review results.

2.3.2 Algorithm for RQ4. To exploit the potential of LLMs in producing safer code, we design an iterative repair algorithm for RQ4, as shown in Algorithm 1. Taking code generation tasks (T) as input, it initially utilizes a LLM to generate code ($LLM_gen()$) according to given task descriptions. Subsequently, it employs an automatic tool ($scanner()$), CodeQL and Bandit are used in RQ4) to scan the generated code for vulnerabilities. If a piece of code is free of weaknesses, it is output as secure code. Otherwise, it is returned to the LLM for repair ($LLM_repair()$), with CWE information provided ($INFO_{CWE}$). This scan-and-repair process is conducted iteratively until the code is secure or the predefined maximum number of iterations (k) is reached.

It is worth noting that the “scanner” in the algorithm is not predefined. Initially, we planned to use LLMs for vulnerability self-detection. However, as discovered in RQ2, LLMs are unable to provide reliable detection results. Alternatively, semantic analysis engines such as CodeQL and Bandit have been adopted.

Algorithm 1: The algorithm for secure code agent

Input: Set of code generation tasks, T ; Max iteration, k
Output: Set of secure code snippets, S

```

1  $S \leftarrow \emptyset, V \leftarrow \emptyset, i \leftarrow 1$ 
2 for  $t$  in  $T$  do
3    $p \leftarrow \text{LLM\_gen}(t), (failed, INFO_{CWE}) \leftarrow \text{scanner}(p)$ 
4   if  $failed$  then
5      $V \leftarrow V \cup \{(p, INFO_{CWE})\}$ 
6   else
7      $S \leftarrow S \cup \{p\}$ 
8   end
9 end
10 while  $i \leq k$  and  $V \neq \emptyset$  do
11    $V_{temp} \leftarrow \emptyset$ 
12   for  $(v, INFO_{CWE})$  in  $V$  do
13      $v_{fix} \leftarrow \text{LLM\_repair}(v, INFO_{CWE})$ 
14      $(failed, INFO_{CWE}) \leftarrow \text{scanner}(v_{fix})$ 
15     if  $failed$  then
16        $V_{temp} \leftarrow V_{temp} \cup \{(v_{fix}, INFO_{CWE})\}$ 
17     else
18        $S \leftarrow S \cup \{v_{fix}\}$ 
19     end
20   end
21    $V \leftarrow V_{temp}$ 
22    $i \leftarrow i + 1$ 
23 end
24 return  $S$ 

```

2.3.3 Method of Code Review. Code snippets generated or repaired by LLMs need to undergo review to determine whether they are vulnerable to the specified CWEs. For instance, code generated for task CWE-089/author_1.py will be examined for the existence of CWE-89 (SQL Injection). *We do not inspect the presence of other CWE vulnerabilities* for (1) it is impossible for any method to encompass the entire spectrum of possible CWEs; (2) according to the design of SecurityEval, the generated code is most likely to exhibit the predefined vulnerabilities; and (3) focusing on predefined vulnerabilities is a common practice in previous studies such as [25, 26, 30]. To ensure maximum accuracy, we perform 3 independent rounds of review for each piece of code:

(1) **CodeQL** is an open-source semantic code analysis engine developed and maintained by GitHub, capable of detecting code vulnerabilities in various programming languages [2]. It is also the tool supporting GitHub Advanced Security features [3]. CodeQL officially supports scanning (i.e., provides query scripts) for 29 CWEs and 1 CVE directly related to security in Python [9]. Of these, 26 CWEs are among the 69 CWEs in SecurityEval, covering 67 out of 121 pieces of its code. We choose CodeQL because of its

status as an industry-leading engine for static code analysis and its widespread use in software security research. The version we used is CodeQL CLI v2.16.6.

(2) **Bandit** is a semantic code analysis tool specifically designed for Python by PyCQA (an organization for Python code standardization). Bandit is able to traverse code files, build abstract syntax trees, and report potential security vulnerabilities in CWE [1]. We chose Bandit for our research because it is tailored for Python, aligning closely with the focus of our work. The version utilized in our experiment is Bandit 1.7.8.

(3) **Manual Review.** Since CodeQL and Bandit do not comprehensively cover all CWEs in the SecurityEval dataset, 4 reviewers were tasked with conducting independent manual code reviews as a supplementary measure. During this process, the reviewers primarily referred to the example insecure code provided by SecurityEval for each task, as well as the CWE definitions available on the official MITRE website². In cases of disagreement, the final decision was made by an expert in Software Engineering following a group discussion with the reviewers. This approach ensures a thorough evaluation of potential vulnerabilities beyond the scope of automated analysis tools.

We consider a piece of code x to be vulnerable to its corresponding CWE if it has been identified as insecure in any of the three rounds of review, as described in (1) where $Vul(x)$ denotes whether the code is vulnerable.

$$Vul(x) = \begin{cases} True & Manual(x) \parallel Codeql(x) \parallel Bandit(x) \\ False & \text{else} \end{cases} \quad (1)$$

2.4 Prompts and Parameters

This subsection describes the prompts (in *zero-shot* fashion) and parameters used in our research. **Due to the large number of cases and the significant effort required for manual review, we only focused on the performance of the LLMs under the following set of prompts:**

(1) **Prompt for Code Generation.** By referring to the OpenAI official website for guidance [7, 23], we construct the following prompt for code generation, where $\langle \text{Code} \rangle$ denotes a generation task in the SecurityEval dataset:

“You are a programming assistant, your task is to complete the following Python code according to comments faithfully: $\langle \text{Code} \rangle$ ”

The above prompt is used in RQ1 and RQ4.

(2) **Prompt for Vulnerability Detection.** We refer to relevant work on LLMs for vulnerability detection [16, 27, 36] to construct the following prompt used in RQ2, in which $\langle \text{SN} \rangle$ and $\langle \text{Def} \rangle$ respectively denote the serial number and the definition of the CWE:

“Your task is to determine whether the following Python code is vulnerable to CWE- $\langle \text{SN} \rangle$ ($\langle \text{Def} \rangle$). Return True for vulnerable or False for invulnerable.”

(3) **Prompt for Vulnerability Repair.** We refer to the examples for fixing bugs in Python programs on the OpenAI website [8] to construct the following prompt for code repair which is used in RQ3 and RQ4:

²<https://cwe.mitre.org>

Table 2: Vulnerable code pieces generated by the LLMs

Model	#Vul	Model	#Vul
GPT-3.5	92/121 (76.0%)	Code Llama	91/121 (75.2%)
GPT-4	91/121 (75.2%)	CodeGeeX2	95/121 (78.5%)
Avg.	369/484 (76.2%)		

“You will be provided with a piece of Python code vulnerable to CWE-<SN>(<Def>). Your task is to generate the complete fixed code.”

(4) Parameters. To strike a balance between the models’ creativity and the reproducibility of our work, we did not override the default parameters of the models. For the GPT family, default values of the parameters are temperature=1, top_p=1, etc. [23], while for Code Llama they are temperature=0.1, top_p=1, etc [10]. Unfortunately, the default values of CodeGeeX2’s parameters remain undisclosed.

We prompt the LLMs to complete all given tasks *in separate conversations*.

2.5 Experimental Platform

In this work, we access all LLMs through remote APIs. Results generated by GPT-3.5, GPT-4, and Code Llama are obtained via APIs provided by OpenAI³ and NVIDIA⁴. CodeGeeX2 is accessed through the CodeGeeX extension v2.8.0 for VSCode⁵. CodeQL, Bandit, and all the Python scripts used in our work are run locally on a single desktop-class PC equipped with an Intel i5-11300H processor and 16 GB DDR4 RAM.

3 STUDY OF RQ1

3.1 Overview

In this section, we have GPT-3.5, GPT-4, Code Llama, and CodeGeeX2 generate code for tasks in the SecurityEval dataset with the prompt and parameters described in 2.4. Overall, 484 pieces of code have been generated (121 pieces by each of the 4 LLMs). We then automatically and manually review all the generated code with the method described in 2.3.3.

3.2 Results and Analysis

The detailed visual representation of the performance of the 4 LLMs on SecurityEval can be accessed in our repository. As a summary, Table 2 shows the number and percentage of insecure code pieces generated by each model.

Despite their advanced capability in generating functionally correct Python code [6] [37], all four models performed poorly in generating secure code on SecurityEval, with an average of 76.2% of the generated code being insecure. This highlights a significant challenge in using current LLMs for secure code generation and underscores the need for prompting them to detect and fix the vulnerability in their self-generated code, as studied in RQ2, RQ3, and RQ4.

As the emphasis of our work is not on the security of LLM-generated code, which has been extensively addressed in prior

research, a detailed analysis of the performance of the 4 LLMs on SecurityEval is provided in our repository for readers who are interested.

4 STUDY OF RQ2

4.1 Overview

In this section, we investigate whether large language models are qualified code self-reviewers by prompting them to identify vulnerabilities in code produced by themselves. In specific, we ask them whether the specified CWE weakness exists in the code they have generated, and compare their judgments with *the review results gained in RQ1 which serve as the ground truth*. Detailed prompts are presented in 2.4.

Instead of using all four models, we use only GPT-3.5 and GPT-4, as they have demonstrated the ability to generate coherent responses to our queries for vulnerability detection. Code Llama and CodeGeeX2 are excluded because, during our preliminary tests for the capability to detect, they often generate nonsensical responses, regardless of our command to identify weaknesses (part of their responses can be found in our public repository for reference). Overall, GPT-3.5 and GPT-4 generate 968 pieces of judgment (484 by each of the 2 models).

4.2 Results and Analysis

We assessed the correctness of a LLM’s judgment by checking whether it is in agreement with the established ground truth. Equation (2) illustrates the method in a formalized way, in which *Tech* represents either GPT-3.5 or GPT-4.

$$Acc_{Tech}(x) = \begin{cases} True & Tech(x) == Vul(x) \\ False & else \end{cases} \quad (2)$$

Detailed results of this section are available in our repository, while Table 3 provides a statistical summary of the accuracy of GPT-3.5 and GPT-4 in detecting vulnerabilities in code produced by all four LLMs.

On average, GPT-3.5 achieves 43.6% accuracy, which is comparable to random-guess baseline (~50%). This suggests that GPT-3.5’s ability to detect vulnerabilities is of limited practical value. GPT-4, on the other hand, achieves an average accuracy of 74.6%, demonstrating its superior ability to understand and analyze code. The experimental results are largely consistent with previous related work based on real-world code [27].

In addition to accuracy, false positive rate (FPR) is another crucial metric for assessing the reliability of a detection technique. By *only considering the results of the manual review in RQ1 as the ground truth*, we determine a judgment as false positive using (3), in which $FP_{Tech}(x)$ denotes whether a result of *Tech* (GPT-3.5, GPT-4, CodeQL, or Bandit) is false positive.

$$FP_{Tech}(x) = \begin{cases} True & Tech(x) \&\& !Manual(x) \\ False & else \end{cases} \quad (3)$$

Fig. 3 presents the false positive rates of GPT-3.5, GPT-4, CodeQL, and Bandit. The FPRs of CodeQL and Bandit serve as baselines for assessing the trustworthiness of GPT-3.5 and GPT-4 as code reviewers. Overall, the FPR of GPT-3.5 reaches 4.3%, while that of GPT-4

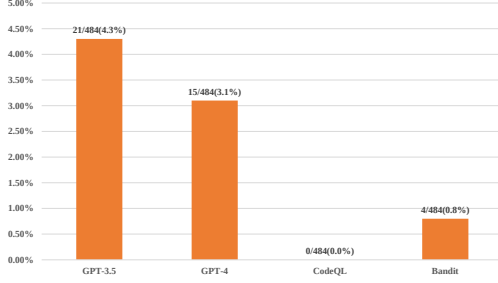
³<https://api.openai.com/v1/chat/completions>

⁴<https://integrate.api.nvidia.com/v1>

⁵<https://marketplace.visualstudio.com/items?itemName=amin.codegeex>

Table 3: GPT-3.5’s and GPT-4’s Accuracy in identifying vulnerabilities in code generated by the 4 LLMs

Model for Detection	Model for Generation				Avg.
	GPT-3.5	GPT-4	Code Llama	CodeGeeX2	
GPT-3.5	58/121 (47.9%)	52/121 (43.0%)	52/121 (43.0%)	49/121 (40.5%)	211/484 (43.6%)
GPT-4	91/121 (75.2%)	90/121 (74.4%)	87/121 (71.9%)	93/121 (76.9%)	361/484 (74.6%)

**Figure 3: False positive rates of the 4 studied techniques**

is 3.1%, both of which are unacceptably high. In contrast, CodeQL and Bandit yield relatively low false positive rates (below 1%). This indicates that both tested LLMs have a significant likelihood of incorrectly identifying secure code as vulnerable. Consequently, **neither GPT-3.5 nor GPT-4 can be relied upon for accurate vulnerability detection in the code they generated.**

5 STUDY OF RQ3

5.1 Overview

In this section, we investigate whether large language models are capable of effective code self-repair by prompting them to fix weaknesses in previously identified vulnerable code snippets. Subsequently, we manually and automatically examine whether the pieces are fixed with the method described in 2.3.3.

Only GPT-3.5 and GPT-4 are included in this analysis, for the same reason in RQ2. Prompts used in this part have been detailed in 2.4. In total, GPT-3.5 and GPT-4 generated 738 pieces of repaired code (369 pieces of vulnerable code generated by the 4 LLMs in RQ1, repaired respectively by GPT-3.5 and GPT-4), all of which underwent both manual and automated review as outlined in 2.3.3.

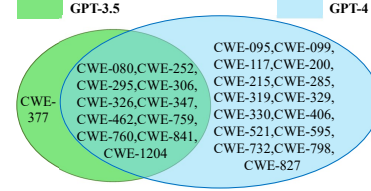
5.2 Results and Analysis

Detailed results of this RQ can be accessed in our repository, which includes visualizations of GPT-3.5’s and GPT-4’s performance in repairing vulnerable code with each CWE.

Table 4 presents the success rates of repair computed using (4), in which N_{vul} denotes the number of vulnerable code snippets and N_{fix}^1 denotes the number of those who were successfully repaired (superscript 1 stands for one single attempt).

$$R_{fix}^1 = \frac{N_{fix}^1}{N_{vul}} \times 100\% \quad (4)$$

5.2.1 Statistical Analysis. Table 4 demonstrates that GPT-3.5 and GPT-4 are capable of repairing a range of LLM-generated insecure

**Figure 4: The Venn diagram of CWEs where all vulnerable code generated by the 4 LLMs is fixed by GPT-3.5 or GPT-4**

code when provided with a description of the CWE type. Notably, GPT-4 performs significantly better than GPT-3.5, with nearly twice the success rate of repair. Although there are no pre-existing techniques as baselines to compare with (to the best of our knowledge, there has been no automated technique such as APR tools that can effectively fix security vulnerabilities in Python programs), **it can be concluded that advanced large language models such as GPT-4 have a promising level of ability to repair vulnerabilities in the code generated by themselves or other LLMs.**

As emphasized in Table 4, GPT-3.5 achieves a success rate of 30.4% when attempting to fix its own generated code, marking its poorest performance across all code repair tasks. Similarly, GPT-4 has its lowest success rate of 54.3% when fixing the code it generated. **This evidence suggests that large language models tend to experience a decline in performance when attempting to fix vulnerabilities generated by themselves. However, this finding needs to be tested across a broader spectrum of scenarios to ensure its validity.** This insight is particularly interesting and noteworthy, as it sheds light on the limitations of LLMs in improving the content generated by themselves.

5.2.2 Scenario-relevant Analysis. Fig. 4 illustrates the CWE scenarios in which GPT-3.5 and GPT-4 successfully repaired all vulnerabilities in the code generated by the four LLMs. GPT-3.5 successfully repaired all the vulnerable code snippets in 12 CWE categories, while GPT-4 achieved this in 26 CWE categories, with 11 CWEs being common to both models. It is evident that GPT-3.5’s coverage of success repair is nearly a subset of GPT-4’s, indicating that GPT-4 was able to address significantly more CWE scenarios than GPT-3.5.

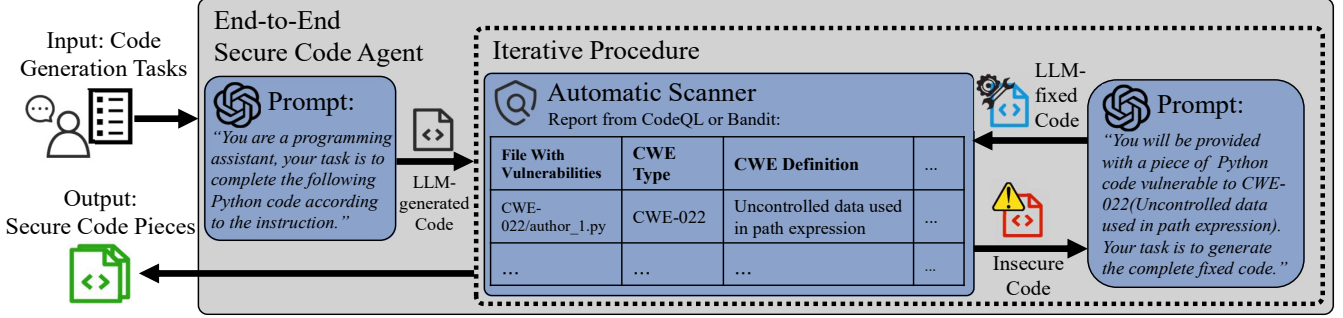
6 STUDY OF RQ4

6.1 Overview

RQ2 and RQ3 respectively represent the stages of code review and refactoring of the end-to-end procedure. However, one single round may not be sufficient to address all security issues, as indicated in RQ3. Therefore, in RQ4, we investigate the effectiveness of implementing an iterative strategy that repeatedly conducts vulnerability

Table 4: GPT-3.5’s and GPT-4’s success rates of repairing code generated by the 4 LLMs in a single attempt (R_{fix}^1)

Model for Repair	Model for Generation				Avg.
	GPT-3.5	GPT-4	Code Llama	CodeGeeX2	
GPT-3.5	28/92 (30.4%)	30/91 (33.0%)	31/91 (34.1%)	34/95 (35.8%)	123/369 (33.2%)
GPT-4	56/92 (60.9%)	50/91 (55.0%)	58/91 (63.7%)	56/95 (58.9%)	220/369 (59.6%)

**Figure 5: The design of our end-to-end secure code agent**

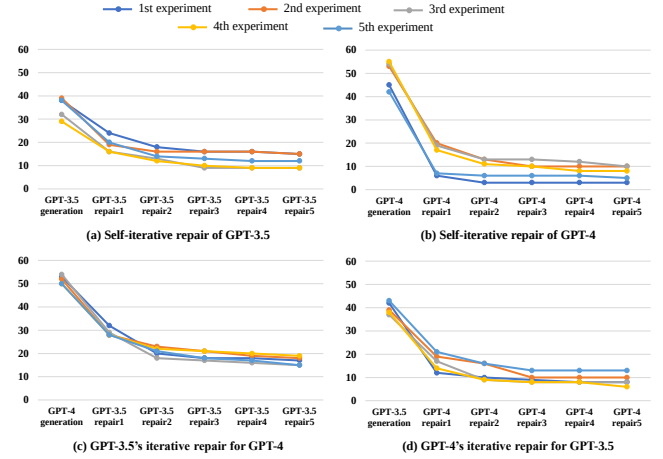
detection and repair to enhance LLMs’ repair capability. With multiple rounds of attempts and specific feedback provided, we expect LLMs to produce source code with less vulnerabilities.

Since this process produces a large amount of generated and repaired code, we developed an automated tool implementing the algorithm described in Algorithm 1. As depicted in Table 5, our tool for RQ4 consists of a code generator, a vulnerability scanner, and a vulnerability repairer. The roles of the code generator and repairer are performed by the LLMs being evaluated. *Instead of using LLMs as scanners, we utilize reliable semantic code analysis engines (CodeQL and Bandit) in the tool, given that GPT-3.5 and GPT-4 have demonstrated their inability to correctly identify vulnerabilities in RQ2.* We only manually examine the final pieces of code generated after all iterations.

The tool takes as input files containing code generation tasks. It first calls the API of the LLM which serves as the generator to produce code snippets based on the task description. Its scanner then scans the generated code files for weaknesses according to CWE specifications. A piece of generated code is deemed vulnerable by the tool if reported as insecure by either of the two engines.

Code snippets free of weaknesses will be output as secure code, while those found to have vulnerabilities are returned to the LLM who serves as repairer for remediation, given the CWE information of the weaknesses (provided by CodeQL or Bandit). This scan-and-repair process is conducted in an iterative manner until all code is regarded as secure code or the predefined maximum iterations are reached. This tool is available in the public repository of our work.

As outlined in 2.3.3, CodeQL is capable of scanning for 26 CWEs in SecurityEval, corresponding to 67 code generation tasks, while Bandit’s coverage remains undisclosed to us. Therefore, *to align with the detection capabilities of the automated analysis tools, we used only the 67 out of 121 code generation tasks from the SecurityEval dataset that are directly analyzable by CodeQL in RQ4.* This approach

**Figure 6: Line chart depicting the number of vulnerable code pieces identified by CodeQL or Bandit across each iteration**

ensures that predefined CWE risks can be detected by at least one of the two analysis tools.

Four experimental setups were designed for RQ4: GPT-3.5 self-repairing code from GPT-3.5, GPT-4 self-repairing code from GPT-4, GPT-3.5 cross-repairing code from GPT-4, and GPT-4 cross-repairing code from GPT-3.5. We conducted 5 independent experiments for each setup to mitigate random factors. In total, the 20 experiments produced and automatically examined about 3,500 code pieces. Finally, we manually reviewed the code generated from the last repair round.

6.2 Results and Analysis

Fig. 6 depicts the results of repair across each iteration using the tool we developed.

Table 5: Averaged cumulative success rates ($\bar{R}_{fix}^5$)

Model for Repair	Model for Generation	
	GPT-3.5	GPT-4
GPT-3.5	65.9%	67.6%
GPT-4	77.4%	85.5%

As a quantitative summary of Fig. 6, Table 5 presents the averaged cumulative success rates after five consecutive repair iterations. These rates are computed using (5), where $\bar{N}_{vul}$ represents the mean of the number of vulnerable code snippets initially identified by CodeQL or Bandit following the code generation phase of the 5 independent experiments of each setup, and $\bar{N}_{fix}^5$ denotes the mean of number of those who were successfully repaired within or by the conclusion of the 5th iteration (superscript 5 stands for five iterative attempts).

$$\bar{R}_{fix}^5 = \frac{\bar{N}_{fix}^5}{\bar{N}_{vul}} \times 100\% \quad (5)$$

Across the 20 experiments (5 experiments for each of the 4 setups), CodeQL and Bandit initially identified an average of about 45 vulnerable code pieces. As the iterative repair process progressed, the number of detected vulnerabilities significantly decreased. After the final iteration, only an average of 10 code pieces are still found to have weaknesses. On average, GPT-3.5 and GPT-4 successfully repaired 65.9% ~ 67.6% and 77.4% ~ 85.5% of initial vulnerable code pieces, respectively. These success rates are significantly higher than those observed in RQ2, where only a single repair attempt was made. **The results highlight feedback-driven self-iterative repair as a promising approach for LLMs to enhance security in the code they have generated.**

Observed from Fig 6, the reduction slows down considerably after the second repair iteration, indicating that the efficacy of iterative repairs is approaching its limit. While iterative repair does improve the success rate of repair, it becomes evident that **excessive iterations contribute little to enhancing the overall repair efficiency**. Additionally, excessive iterations can be time-consuming and expensive, which highlights a critical trade-off between code functionality, security, and development efficiency.

7 IMPLICATIONS AND DISCUSSIONS

7.1 LLMs’ awareness of security risks

In RQ1, it was observed that LLMs produced a significant amount of insecure code when tasked with scenarios involving specific security risks. However, the result does not necessarily imply that LLMs are incapable of generating more secure code, for they were able to correct many of the vulnerabilities present in their generated code when prompted to do so. We posit that the production of vulnerable code by LLMs largely stems from their lack of awareness regarding security issues, as they primarily prioritize fulfilling functional requirements. In real-world scenarios, software developers do not always provide LLMs with information about relevant risks. Therefore, it is crucial to enhance the scenario-relevant security awareness of LLMs, particularly that of code language models

which are designed for code-related tasks. Additionally, it is recommended that users explicitly include brief descriptions of potential security weaknesses in prompts to guide LLMs in preventing them.

7.2 Self-repair “blind spots” of LLMs

An intriguing observation from RQ3 is that both GPT-3.5 and GPT-4 achieve their lowest success rates when repairing code generated by themselves (as revealed in Table 4). This suggests that similar to human programmers who tend to overlook the weaknesses in their self-written source code, LLMs also exhibit “blind spots” in code self-repairing. We presume that the phenomenon exists because LLMs are too dependent on the programming patterns learned from their training stage that they tend to “insist” on these patterns rather than exploring alternative approaches, leaving vulnerabilities unfixed when prompted to address self-produced weak code. Conversely, when fixing insecure code generated by other models, a large language model can leverage its unique patterns to address weaknesses that other LLMs may overlook, resulting in a slightly higher success rate of repair.

8 THREATS TO VALIDITY

Choice of the Dataset: The SecurityEval dataset used in our work was released two years prior to our research and might have been included in the training data of LLMs. Despite this possibility, all 4 tested LLMs exhibit poor performance in terms of security quality when assessed against this benchmark. Therefore, the security problem of large language models for code remains an open challenge and our conclusions drawn from the experiments with SecurityEval maintain their validity and relevance.

Limitations of Code Review: While manual code review is a prevalent practice in the software engineering community, it does not guarantee 100% accuracy because of subjective factors. Moreover, the security of code remains an open question, as standards for secure coding may evolve with the emergence of new attack methods or updates to library functions (e.g., Python standard modules). Nevertheless, we are confident that our method for code review described in 2.3.3 provides largely reliable judgments. Additionally, we make the review results publicly accessible in our repository.

Limitations of Experimental Design: Due to time constraints, we did not fully explore the potential of LLMs in terms of prompt engineering. It is conceivable that prompts with more detailed task descriptions, such as specifying the row and column numbers of vulnerabilities or using different prompting styles, could influence the performance of LLMs.

9 RELATED WORK

(1) Vulnerabilities in LLM-generated code. Pearce et al. were among the first to evaluate the security of C and Python code generated by GitHub Copilot across 25 CWE cases, finding that 40% of the code was vulnerable [25]. Furthermore, [13, 17, 18, 20, 29] also examine LLMs’ ability to generate secure code in various settings. A more recent study by Tihanyi et al. examined the security of C code generated by GEMINI-pro, GPT-4, and other models, revealing that at least 63.47% of the generated programs were vulnerable [32], which is a number close to our findings on Python. These results

highlight the inability of current LLMs to consistently generate secure code without elaborately designed prompts.

(2) LLMs for detecting vulnerabilities in real-world code.

Recent research has increasingly focused on the direct application of LLMs in enhancing code security, particularly in the areas of vulnerability detection and repair [38]. Fu et al. investigated the ability of LLMs to detect and classify weaknesses in real-world code [16]. Purba et al. applied 4 well-known LLMs to detect vulnerabilities in 2 datasets. They found a significant performance gap between the studied LLMs and static analysis tools, primarily due to LLMs’ high false positive rates [27], a result consistent with our conclusion in RQ2. Other research also highlighted the limitations of current LLMs in vulnerability detection compared to static analysis tools or specially trained, deep learning-based models [31, 36]. Contrary to these findings, some researchers have observed LLMs’ superiority in specific experimental settings [39][12]. Ullah et al. designed SecLLMHolmes, an automated evaluation framework that investigates LLMs’ reliability in identifying and reasoning about security-related bugs [33]. Yang et al. proposed a novel framework that reinforces LLMs with deep learning-based techniques, achieving state-of-the-art performance in vulnerability detection [35].

(3) LLMs for repairing vulnerabilities in real-world code.

Research results vary regarding the efficacy of large language models in vulnerability repair. A study by Pearce et al. indicates that LLMs are promising zero-shot vulnerability fixers [26]. Wu et al. highlighted the advantages of Codex over traditional deep learning-based repair tools for addressing CWE weaknesses in Java code [34]. Le et al. concluded that ChatGPT provides satisfactory repair results for JavaScript code when detailed descriptions of the vulnerabilities are given [19]. Ahmad et al. found that LLMs such as Codex can effectively fix security bugs in Verilog, a hardware programming language [11]. Conversely, Fu et al. reported that LLMs such as GPT-3.5 underperform compared to traditional models like CodeBERT in vulnerability repair tasks [16].

It is noteworthy that most previous research focuses solely on LLMs’ efficacy in detecting and fixing vulnerabilities in real-world, manually written code. **While these studies provide valuable insights, they do not fully reveal the potential of LLMs to be end-to-end secure code agents who must detect and repair vulnerabilities in the code snippets generated by themselves. This underscores the need for our research specifically targeting the security of LLM-generated code.**

10 CONCLUSIONS AND PERSPECTIVES

In this paper, we seek an answer to the question of how well LLMs serve as end-to-end secure code agents for Python. We first investigate the vulnerabilities in Python source code generated by GPT-3.5, GPT-4, Code Llama, and CodeGeeX2 on the SecurityEval benchmark. Subsequently, we explore LLMs’ potential to independently enhance the security of the code through code self-review and vulnerable code self-repair. Overall, we manually or automatically examined around 4,900 code pieces.

Our study reveals several key findings: (1) LLMs tend to generate insecure code in security-critical programming tasks because of shortage of scenario-relevant awareness of potential risks; (2) LLMs such as GPT-3.5 and GPT-4 are not capable of accurately identifying

vulnerabilities in the source code they produce, primarily due to their high false positive rates; (3) advance LLMs can achieve up to a 60% success rate repairing insecure code generated by other LLMs, but they exhibit relatively poor performance when repairing self-produced code; (4) Leveraging semantic code analysis engines, a feedback-driven self-iterative repair approach significantly enhances the security of LLM-generated code.

While we hold the belief that future LLMs have the potential to produce secure code in an end-to-end fashion, current models are unable to serve as reliable secure code agents without assistance from established tools like semantic code analysis engines.

Our study also leads us to the following viewpoints:

(1) We recommend that software developers explicitly highlight potential security risks when instructing large language models to generate source code.

(2) We suggest augmenting LLMs for code with scenario-specific fine-tuning to enhance their security awareness to mitigate potential vulnerabilities.

(3) We advocate for efforts to expand the coverage of semantic code analysis engines such as CodeQL, increasing their capability to detect a wider range of CWEs for the benefit of automated and reproducible research.

11 ACKNOWLEDGMENTS

In the preparation of this manuscript, ChatGPT was utilized to refine certain sentences to enhance their clarity, precision, and academic rigor. However, the core ideas, analysis, and conclusions remain entirely the authors’ own. The use of AI-assisted editing was strictly limited to linguistic improvements and did not influence the scholarly integrity or originality of the research.

References

- [1] 2024. *Bandit documentation*. <https://bandit.readthedocs.io/en/latest/> Accessed 26 May 2024.
- [2] 2024. *CodeQL documentation*. <https://codeql.github.com/docs/codeql-overview/about-codeql/> Accessed 20 May 2024.
- [3] 2024. *GitHub documentation*. <https://docs.github.com/en/get-started/learning-about-github/about-github-advanced-security> Accessed 26 May 2024.
- [4] 2024. *Introduction of CodeGeeX copilot*. <https://codegeex.cn/> Accessed 22 May 2024.
- [5] 2024. *Introduction of CodeGeeX2 model*. <https://github.com/THUDM/CodeGeeX2> Accessed 22 May 2024.
- [6] 2024. *Performance on HumanEval*. <https://paperswithcode.com/sota/code-generation-on-humaneval> Accessed 22 May 2024.
- [7] 2024. *Prompt engineering*. <https://platform.openai.com/docs/guides/prompt-engineering> Accessed 20 May 2024.
- [8] 2024. *Python bug fixer*. <https://platform.openai.com/examples/default-fix-python-bugs> Accessed 20 May 2024.
- [9] 2024. *Query scripts of CodeQL for security*. <https://github.com/github/codeql/tree/main/python/ql/src/Security> Accessed 20 May 2024.
- [10] 2024. *The model card of Code Llama-70B*. <https://build.nvidia.com/meta/codellama-70b> Accessed 27 May 2024.
- [11] Baleegh Ahmad, Shailja Thakur, Benjamin Tan, Ramesh Karri, and Hammond Pearce. 2024. On Hardware Security Bug Code Fixes by Prompting Large Language Models. *IEEE Transactions on Information Forensics and Security* 19 (2024), 4043–4057. <https://doi.org/10.1109/TIFS.2024.3374558>
- [12] Vishwanath Akuthota, Raghunandan Kasula, Sabiha Tasnim Sumona, Masud Mohiuddin, Md Tanzim Reza, and Md Mizanur Rahman. 2023. Vulnerability Detection and Monitoring Using LLM. In *2023 IEEE 9th International Women in Engineering (WIE) Conference on Electrical and Computer Engineering (WIECON-ECE)*. 309–314. <https://doi.org/10.1109/WIECON-ECE60392.2023.10456393>
- [13] Owura Asare, Meiyappan Nagappan, and N Asokan. 2023. Is github's copilot as bad as humans at introducing vulnerabilities in code? *Empirical Software Engineering* 28, 6 (2023), 129.
- [14] Thomas Dohmke. 2023. *The economic impact of the AI-powered developer lifecycle and lessons from GitHub Copilot*. <https://github.blog/2023-06-27-the-economic-impact-of-the-ai-powered-developer-lifecycle-and-lessons-from-github-copilot/> Accessed 20 May 2024.
- [15] Martin Fowler. 2018. *Refactoring: improving the design of existing code*. Addison-Wesley Professional.
- [16] Michael Fu, Chakkrit Tantithamthavorn, Van Nguyen, and Trung Le. 2023. ChatGPT for Vulnerability Detection, Classification, and Repair: How Far Are We? *arXiv:2310.09810* [cs.SE]
- [17] Yujia Fu, Peng Liang, Amjed Tahir, Zengyang Li, Mojtaba Shahin, Jiaxin Yu, and Jinfu Chen. 2023. Security weaknesses of copilot generated code in github. *arXiv preprint arXiv:2310.02059* (2023).
- [18] Raphaël Khoury, Anderson R. Avila, Jacob Brunelle, and Baba Mamadou Camara. 2023. How Secure is Code Generated by ChatGPT? *arXiv:2304.09655* [cs.CR]
- [19] Tan Khang Le, Saba Alimadadi, and Steven Y. Ko. 2024. A Study of Vulnerability Repair in JavaScript Programs with Large Language Models. In *Companion Proceedings of the ACM on Web Conference 2024 (WWW '24)*. ACM. <https://doi.org/10.1145/3589335.3651463>
- [20] Zhijie Liu, Yutian Tang, Xiapu Luo, Yuming Zhou, and Liang Feng Zhang. 2024. No need to lift a finger anymore? assessing the quality of code generation by chatgpt. *IEEE Transactions on Software Engineering* (2024).
- [21] Madhav Nair, Rajat Sadhukhan, and Debdeep Mukhopadhyay. 2023. Generating secure hardware using chatgpt resistant to cwes. *Cryptology ePrint Archive* (2023).
- [22] CBS News. 2023. *ChatGPT is growing faster than TikTok*. <https://www.cbsnews.com/news/chatgpt-chatbot-tiktok-ai-artificial-intelligence/> Accessed 7 May 2024.
- [23] OpenAI. 2023. *Introductions of the Chat Completion API*. <https://platform.openai.com/docs/api-reference/chat/create> Accessed 7 May 2024.
- [24] OpenAI. 2024. GPT-4 Technical Report. *arXiv:2303.08774* [cs.CL]
- [25] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the keyboard? assessing the security of github copilot's code contributions. In *2022 IEEE Symposium on Security and Privacy (SP)*. IEEE, 754–768.
- [26] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining zero-shot vulnerability repair with large language models. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2339–2356.
- [27] Moumita Das Purba, Arpita Ghosh, Benjamin J. Radford, and Bill Chu. 2023. Software Vulnerability Detection using Large Language Models. In *2023 IEEE 34th International Symposium on Software Reliability Engineering Workshops (ISSREW)*. 112–119. <https://doi.org/10.1109/ISSREW60843.2023.00058>
- [28] Baptiste Rozière, Jonas Gehring, Fabian Gloeckle, Sten Sootla, Itai Gat, Xiaoqing Ellen Tan, Yossi Adi, Jingyu Liu, Romain Sauvestre, Tal Remez, Jérémy Rapin, Artyom Kozhevnikov, Ivan Evtimov, Joanna Bitton, Manish Bhatt, Cristian Canton Ferrer, Aaron Grattafiori, Wenhan Xiong, Alexandre Défossez, Jade Copet, Faisal Azhar, Hugo Touvron, Louis Martin, Nicolas Usunier, Thomas Scialom, and Gabriel Synnaeve. 2024. Code Llama: Open Foundation Models for Code. *arXiv:2308.12950* [cs.CL]
- [29] Gustavo Sandoval, Hammond Pearce, Teo Nys, Ramesh Karri, Siddharth Garg, and Brendan Dolan-Gavitt. 2023. Lost at c: A user study on the security implications of large language model code assistants. In *32nd USENIX Security Symposium (USENIX Security 23)*. 2205–2222.
- [30] Mohammed Latif Siddiq and Joanna CS Santos. 2022. SecurityEval dataset: mining vulnerability examples to evaluate machine learning-based code generation techniques. In *Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security*. 29–33.
- [31] Benjamin Steenhoek, Md Mahbubur Rahman, Monoshi Kumar Roy, Mirza Sanjida Alam, Earl T. Barr, and Wei Le. 2024. A Comprehensive Study of the Capabilities of Large Language Models for Vulnerability Detection. *arXiv:2403.17218* [cs.SE]
- [32] Norbert Tihanyi, Tamas Bisztray, Mohamed Amine Ferrag, Ridhi Jain, and Lucas C. Cordeiro. 2024. Do Neutral Prompts Produce Insecure Code? FormAI-v2 Dataset: Labelling Vulnerabilities in Code Generated by Large Language Models. *arXiv:2404.18353* [cs.CR]
- [33] Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Coskun, and Gianluca Stringhini. 2024. LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks. In *IEEE Symposium on Security and Privacy*.
- [34] Yi Wu, Nan Jiang, Hung Viet Pham, Thibaud Lutellier, Jordan Davis, Lin Tan, Petr Babkin, and Sameena Shah. 2023. How Effective Are Neural Networks for Fixing Security Vulnerabilities. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA '23)*. ACM. <https://doi.org/10.1145/3597926.3598135>
- [35] Yanjing Yang, Xin Zhou, Runfeng Mao, Jinwei Xu, Lanxin Yang, Yu Zhangm, Haifeng Shen, and He Zhang. 2024. DLAP: A Deep Learning Augmented Large Language Model Prompting Framework for Software Vulnerability Detection. *arXiv:2405.01202* [cs.SE]
- [36] Xin Yin, Chao Ni, and Shaohua Wang. 2024. Multitask-based Evaluation of Open-Source LLM on Software Vulnerability. *arXiv:2404.02056* [cs.SE]
- [37] Qinkai Zheng, Xiao Xia, Xu Zou, Yuxiao Dong, Shan Wang, Yufei Xue, Zihan Wang, Lei Shen, Andi Wang, Yang Li, et al. 2023. Codegeex: A pre-trained model for code generation with multilingual evaluations on humaneval-x. *arXiv preprint arXiv:2303.17568* (2023).
- [38] Xin Zhou, Sicong Cao, Xiaobing Sun, and David Lo. 2024. Large Language Model for Vulnerability Detection and Repair: Literature Review and the Road Ahead. *arXiv:2404.02525* [cs.SE]
- [39] Xin Zhou, Ting Zhang, and David Lo. 2024. Large Language Model for Vulnerability Detection: Emerging Results and Future Directions. *arXiv preprint arXiv:2401.15468* (2024).